Professional development for information security specialists

LECTURE NOTES

course:
“Computer Attack Monitoring”

LECTURE 2. MONITORING AND RESPONSE ARCHITECTURE

Roles, monitoring levels, alert quality, false alarms

(2 academic hours)

2026

Contents

1 Introduction 4

2 Roles and processes of a monitoring center 5

2.1 Functions of the center 5

2.2 Roles and levels 5

2.3 How an alert is processed 6

2.4 Metrics of the center 6

3 Architecture of the monitoring system 7

3.1 Monitoring levels 7

3.2 Components and data flow 7

3.3 Example: the Elastic Stack 8

3.4 Normalization and enrichment 9

3.5 Threat data 10

4 Detection rules 11

4.1 The Sigma rule language 11

4.2 Time windows 14

4.3 Steps to create a rule 14

4.4 Adding weak signals 15

5 Alert quality and false alarms 16

5.1 Detection errors 16

5.2 Too many alerts for an analyst 16

5.3 How to reduce false alarms 16

5.4 Detection as code 17

6 Response and its automation 18

6.1 Life cycle of a response 18

6.2 Automation of response 18

7 Summary 19

References 20
8 Self-check questions 22

1 Introduction

Sl. 1

This lecture is about how a computer attack monitoring system is built and who does what in it, from collecting events to responding to an incident. The material is built around one example that runs through all chapters.

Sl. 2

A monitoring system exists to select a small number of alerts from a huge number of events, to confirm incidents among the alerts, and to react to them in time. The order of the lecture (table 1) is: first people and processes, then technical parts, then detection rules, then the quality of alerts, and finally the response.

Table 1 — Order of the lecture

Chapter	Question	Result
1	Who handles the alerts, and in what order?	Roles, levels and the alert handling process
2	Where does the data come from, and how?	Monitoring levels and architecture
3	How do we describe an attack with a rule?	Detection rules and correlation
4	How far can we trust the alerts?	Precision, recall, reducing false alarms
5	What do we do after confirmation?	Response and its automation

Sl. 3, 4

Here is the example. An attacker guesses the password of the account *anna* in a web application. Five failed logins come from the address 203.0.113.7 in two minutes. Then a login succeeds. We need three terms, and the difference between them is the base of all monitoring (table 2). By the NIST glossary, an **event** is any observable occurrence in a network or system [1]. An **alert** is a notice that a specific attack is aimed at the systems of the organization [2]. An **incident** is an occurrence that harms, or is about to harm, the confidentiality, integrity or availability of information or of a system without permission, or that breaks or is about to break security laws, policies and procedures [3].

Table 2 — From an event to an incident

Term	In our example	Who works with it
Event	A record of a failed login: time, address, account, result	Nobody directly: there are tens of thousands
Alert	“Five failures in 10 minutes, then a successful login”: a detection rule fired	First line analyst
Incident	The account *anna* was probably taken over by the attacker	Response team

2 Roles and processes of a monitoring center

2.1 Functions of the center

Sl. 6

A **security operations center** (SOC) does the monitoring and the response. It can be a separate department, a small group, or a duty that people do by schedule. A SOC of any size has five functions (table 3). They follow the main steps of the international incident response guide [4].

Table 3 — Functions of a monitoring center

Function	What it does	Result
Monitoring	Collect and watch events and alerts	We can see what happens
Detection	Rules and methods that find suspicious things	Alerts
Analysis	Check an alert, confirm it or reject it	Decision: incident or false alarm
Response	Contain, remove, recover	The attack stops
Improvement	Learn from the case, tune the rules	Better rules and processes

2.2 Roles and levels

Sl. 7

Analysts work on different levels, so the load is shared in a sensible way (table 4). An easy task is solved fast on the first line. A hard task goes higher with all its context.

Table 4 — Levels of analysts

Level	Role	Tasks
1	First line analyst	Check new alerts: confirm, reject or pass on; add first context
2	Investigation analyst	Deep analysis, event correlation, containment and removal
3	Detection engineer and threat hunter	Write and tune rules, look for threats that no alert showed

Large organizations also have an incident coordinator, who manages work during serious incidents, and a threat intelligence analyst, who gives data about attackers and their methods. Some centers have no levels: one analyst handles an incident from start to end. This needs more skill, but no context is lost when the case is passed on.

In our example, the first line analyst gets the alert about password guessing. The analyst sees the successful login after the failures and passes the case to level 2. Level 2 finds out what the attacker did in the account *anna* after the login.

2.3 How an alert is processed

Sl. 8

Every alert is processed in the same way (figure 1). The first line analyst makes one of three decisions. If the threat is real, the case goes to investigation. If it is a false alarm, we write down the reason and tune the rule. If there is not enough data, we add context and check the alert again.

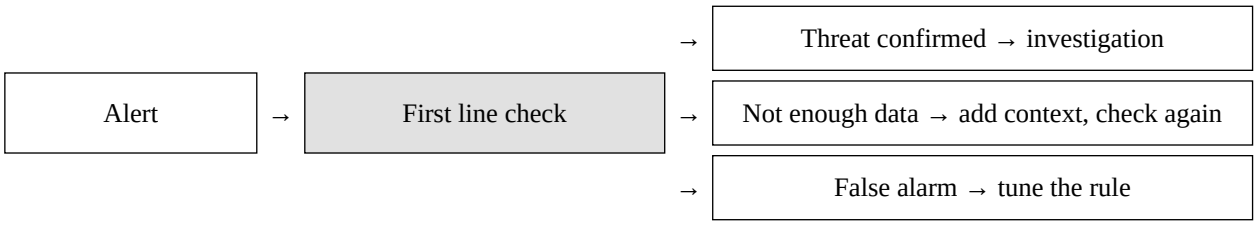


Figure 1 — Decisions when an alert is checked

Sl. 9

For common alerts we write a **runbook** in advance. It lists the checks, the data to collect and the rules for the decision. For example, the runbook for password guessing has these steps: is the source address internal or external; how many failures; which account is attacked (service, administrator, normal); was there a successful login after the failures; if yes, pass the case to level 2 at once.

2.4 Metrics of the center

Sl. 10

We measure the work of the center with numbers (table 5). Each organization sets its own target values, because they depend on the number of analysts and on business needs. So the table shows how to read each number, not a universal norm.

Table 5 — Metrics of a monitoring center

Metric	What it measures	How to read it
Alerts per analyst per shift	Load	If it grows and the staff does not, alerts are missed
Share of alerts passed up	Need for deep analysis	Too low: the first line cannot cope. Too high: the rules are noisy
Average time before the check starts	Speed of the center	Grows when the center is overloaded
Time from attack start to detection	Visibility	The main measure of detection quality
Time from detection to removal	Speed of response	Shows how mature the process is

3 Architecture of the monitoring system

3.1 Monitoring levels

Sl. 12, 13

An attacker leaves traces in many places. So we monitor on several levels at the same time (table 6). No level shows everything. For example, the network level cannot see inside encrypted traffic, and the host level cannot see other hosts.

Table 6 — Monitoring levels

Level	Data sources	What we see	What we do not see
Network	Firewall, traffic sensors, DNS, proxy	Scans, links to outside addresses, data leaving	Content of encrypted traffic
Host	Operating system logs, process start, endpoint protection	Programs that run, persistence in the system	Actions on other hosts
Application	Web application and database logs	User logins, data access, denied access	Attacks that did not reach the application
Accounts	User directory, authentication logs	Logins, rights changes, second factor	What happens after the login
Cloud	Logs of the cloud provider	New resources, changes of access policy	Inside of managed services

In our example, the password guessing is seen at the application level (failed logins) and at the accounts level (the later login). We can also check the attacker’s address at the network level in the proxy data.

3.2 Components and data flow

Sl. 14, 15

Data passes through several parts one after another (figure 2 and table 7). Because the parts are separate, we can change each one alone and scale the weak points.

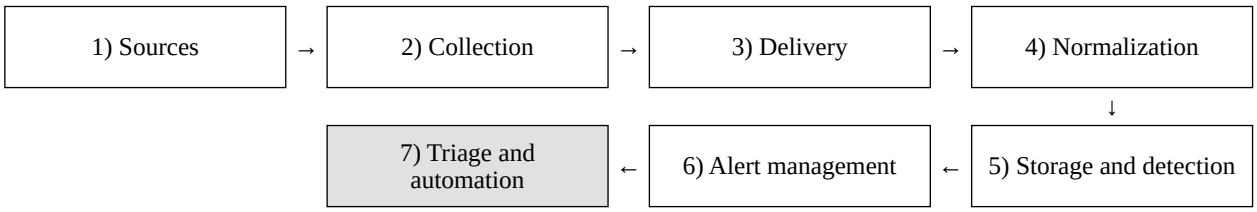


Figure 2 — Data flow in a monitoring system

Table 7 — Parts of a monitoring system

Part	Function	Example products
Collection	Read logs at the source	Fluent Bit, Elastic Agent and Beats, auditd
Delivery	Send to the central store with a buffer	Kafka, Vector, Logstash
Normalization	Bring data to one schema	ECS and OCSF schemas, own parsers
Storage and detection	Indexing, search, running rules	Elasticsearch, OpenSearch, Wazuh, ClickHouse
Alert management	Queue, cases, notifications	Kibana (Elastic Security), TheHive
Automation	Run response scenarios	Shuffle, Cortex

3.3 Example: the Elastic Stack

Sl. 16

Let us see how this scheme is built on the popular Elastic stack. Its parts match the parts of the scheme (table 8). Elastic Agent and Beats read logs at the source. Logstash or the ingest pipeline of Elasticsearch processes and delivers the records. Elasticsearch stores the events and runs the search. Kibana is the interface, and its Elastic Security section has the detection rules, the list of alerts and the case cards [5]. The software Elasticsearch and Kibana is offered under the licenses Elastic License 2.0, SSPL 1.0 and, since August 2024, AGPL 3.0 [6]. So before you use it, check which license fits your organization.

Table 8 — Parts of the monitoring scheme in Elastic Stack

Part of the scheme	In Elastic Stack	What happens in our example
Collection	Elastic Agent, Filebeat	Reads the authentication log of the web application
Delivery and processing	Logstash, ingest pipeline of Elasticsearch	Passes the records on; adds geolocation by address (the geoip processor)
Normalization	ECS schema	Gives the fields common names (table 9)
Storage	Elasticsearch	Stores the events in which failed logins are searched
Detection	Elastic Security rules	Counting failures and a sequence of events (chapter 3)
Alert management	Kibana: alerts and cases	The first line analyst sees the alert and opens a case

The common schema of Elastic is called ECS (Elastic Common Schema). The fields of our training schema from table 10 match it as shown in table 9. In ECS, authentication events have the category `authentication`, and the result has the values `success` and `failure` [5].

Table 9 — Training schema and ECS

Field of the training schema	ECS field	Value in our example
timestamp	`@timestamp`	2026-03-12T09:00:04Z
event_type	`event.category`	`authentication`
actor.id	`user.name`	`anna`
source_ip	`source.ip`	`203.0.113.7`
outcome	`event.outcome`	`failure`

3.4 Normalization and enrichment

Sl. 17

Sources write events in different formats. So before we apply rules, we bring events to one schema. The open schemas OCSF [7] and ECS describe event classes and required fields. A small set of fields is enough for most rules (table 10).

Table 10 — Minimal fields of a normalized event

Field	Purpose	Example
timestamp	Time of the event in one time zone	2026-03-12T09:01:15Z
event_type	Kind of event	auth.login
actor.id	Who acts	anna
source_ip	From where	203.0.113.7
outcome	Result	failure
severity	Importance	low

Sl. 18

Next we add context that is not in the log. This is **enrichment**. It answers the question “how important is this?” (table 11).

Table 11 — Kinds of enrichment

Kind	Where it comes from	Example result
Asset context	List of assets	The address belongs to a production server, high criticality
Location	Geolocation database	The address is from a country that is not usual for the user
Reputation	Threat data	The address is known for password guessing
Account context	User directory	The account belongs to an administrator

For the password guessing alert, enrichment can show that *anna* is an accountant and that the address 203.0.113.7 is on a list of addresses seen in guessing attacks. This makes the alert much more important.

3.5 Threat data

Sl. 19

Data about attacks and attackers comes from outside sources. It has four levels by purpose (table 12).

Table 12 — Levels of threat data

Level	Content	Who uses it
Strategic	Motives of attackers, trends	Management
Tactical	Methods and campaigns of attackers	Detection engineers
Operational	Data about current campaigns	Response team
Technical	Indicators: addresses, domains, hashes	Detection and protection systems

Two OASIS standards are used to share this data between organizations. STIX is a language and format that describes threat data as objects and links [8]. TAXII is a protocol that moves these objects over HTTPS [9]. Sources are open indicator lists, commercial providers, national response centers, industry sharing centers, and the organization’s own incidents.

4 Detection rules

4.1 The Sigma rule language

Sl. 21

It is good to write detection rules in a common language that does not depend on one product. The open standard **Sigma** does this. A rule is written in YAML and then converted to a query of a specific system [10]. A rule has the fields in table 13.

Table 13 — Main fields of a Sigma rule

Field	Purpose
title	Name of the rule
logsource	Which logs the rule uses
detection	Condition that selects events: fields and logic
level	Importance of the alert
falsepositives	When the rule fires on normal behavior
tags	Link to ATT&CK tactics and techniques [11]

We follow the example step by step: which log record makes which line of the rule work, and what we get at the end. The log has five `auth.login` records with the result `failure` for *anna*, from 09:00:04 to 09:02:10, and one record with the result `success` at 09:03:12.

Example 1. Password guessing. First, a base rule selects the needed events from the log:

```
title: Failed login
name: failed_login
logsource: {product: web-app, service: auth}
detection:
    selection: {event_type: auth.login, outcome: failure}
    condition: selection
```

Each line of the rule has a meaning and a result in our example (table 14).

Table 14 — Lines of the base rule and their result

Line	Meaning	What happens in the example
name	The name that other rules use to refer to this rule	The next rules will count these “failed login” events
logsource	Which logs to search	The authentication log of the web application
selection	Selection condition: all listed fields must match	The five records 09:00:04–09:02:10 match. The record at 09:03:12 has `outcome: success`, so it is not selected
condition	When the rule fires	For each matching record: five failed logins

Correlation rules do the counting and the ordering. They refer to base rules. The next rule fires when one account gets five or more failures in ten minutes:

```
title: Password guessing for an account
name: failed_login_burst
correlation:
    type: event_count
    rules: [failed_login]
    group-by: [actor.id]
    timespan: 10m
    condition: {gte: 5}
```

Table 15 — Lines of the correlation rule and their result

Line	Meaning	What happens in the example
type: event_count	Count events	We need the number of failures, not one single error
rules	Which events to count: those the base rule selected	Five failures are counted. The successful login is not counted
group-by	Count separately for each value of the field	Failures of *anna* are not mixed with errors of other users
timespan	Length of the counting window	Five failures in 2 minutes 6 seconds fit into 10 minutes
condition	Threshold	Five is not less than five: the alert appears at 09:02:10, at the fifth failure

The whole chain is: log record → base rule selects a failure → correlation counts failures of one account → threshold reached → alert “password guessing”.

Sl. 22

Example 2. Login after many failures. The guessing alert does not say if the attacker got in. A second correlation rule answers this. It uses the guessing alert (its name is `failed_login_burst`) and a new base rule that selects successful logins:

```
title: Successful login
name: successful_login
logsource: {product: web-app, service: auth}
detection:
    selection: {event_type: auth.login, outcome: success}
    condition: selection
```

```
title: Successful login after many failures
correlation:
    type: temporal_ordered
    rules: [failed_login_burst, successful_login]
    group-by: [actor.id]
    timespan: 15m
```

Table 16 — Lines of the sequence rule and their result

Line	Meaning	What happens in the example
type: temporal_ordered	Events must come in the given order	First the guessing, then the login. A login before the failures gives no alert
rules	List in the right order	Guessing at 09:02:10, successful login at 09:03:12
group-by	Both events have the same value of the field	Both the guessing and the login are for *anna*. A successful login of another user does not match
timespan	Window for the whole chain	About three minutes from the start of guessing to the login, inside 15

Result: six log records become one alert, “successful login after many failures”. This is the alert that the first line analyst gets. In this way we can see which record and which line of the rule led to the alert.

Sl. 23

The same rules can be set in Elastic Security (table 17). A **threshold** rule counts events: you set a grouping field and a minimum number of events, and the schedule of the rule sets the window. To check the number of different values of a field, you add a limit on the number of unique values [12]. A sequence of events is set by a query in the EQL language. For our example, five failures followed by a successful login are written like this [13]:

```
sequence by user.name with maxspan=15m
  [ authentication where event.outcome == "failure" ] with runs=5
  [ authentication where event.outcome == "success" ]
```

Table 17 — Sigma rule types and their analogs in Elastic Security

Sigma	Elastic Security	Parameters in our example
event_count	“Threshold” rule	Group by `user.name`, threshold 5 events
value_count	“Threshold” rule with a limit on the number of values	Group by `source.ip`, at least 8 different `user.name`
temporal_ordered	Event correlation rule (EQL)	`sequence by user.name with maxspan=15m`

Sl. 24

The main types of correlation are in table 18.

Table 18 — Types of Sigma correlation rules

Type	What it checks	Example
event_count	Number of events in a period	Five failed logins in 10 minutes
value_count	Number of different values of a field in a period	One address tries to log in with eight different accounts
temporal	All listed events in a period, in any order	A login and a change of access rights within 15 minutes
temporal_ordered	Events in a given order	Many failures, then a successful login

4.2 Time windows

Sl. 25

A correlation rule counts events in a time window. There are two main kinds of windows: **fixed** windows (one window follows the other) and **sliding** windows (the window moves by a small step). The difference matters when an attack falls on the border of two windows. In figure 3, four failed logins come in minutes 3, 4, 5 and 6. The threshold is three events in five minutes. The fixed windows 0–5 and 5–10 each count two events, so there is no alert. The sliding window that ends at minute 6 has four events, so an alert appears.

Minute	0	1	2	3	4	5	6	7	8	9
Event				●	●	●	●			
Fixed windows	window 0–5: 2 events					window 5–10: 2 events				
Sliding window		window 1–6 (step 1 minute): 4 events								

Figure 3 — Window border: fixed windows miss the attack, the sliding window finds it

So we use sliding windows to find threshold attacks. We keep fixed windows for reports and counting metrics.

4.3 Steps to create a rule

Sl. 26

We create a rule in eight steps (figure 4): decide which attack to find; find out which events it leaves; choose the log; write the selection condition; set the counting and the window; set the importance; write down possible false alarms; test on data and measure the precision.

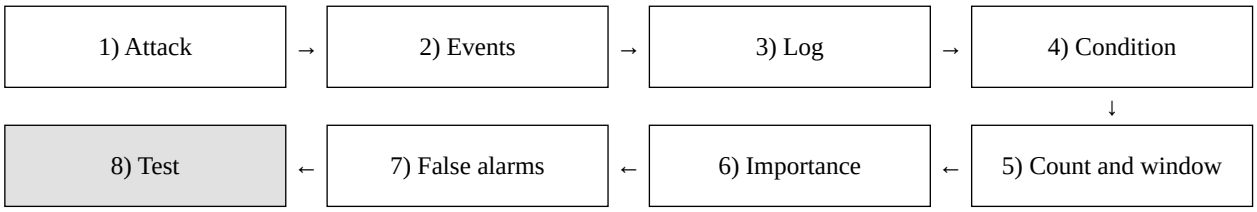


Figure 4 — Eight steps to create a rule

4.4 Adding weak signals

Sl. 27

One weak signal may not be worth sending to an analyst, but several together can be important. We give points to each weak signal. When the sum of points for one account in a period is above a threshold, we create one strong alert (table 19).

Table 19 — Points of weak signals

Weak signal	Points	ATT&CK technique
More than three failed logins	2	T1110
Login from a new country	2	T1078
Successful login after failures	3	T1110
Access to the admin interface	1	T1078
Export of more than 1000 records	3	T1041

If the sum of points for one account in 30 minutes is eight or more, we create a high-importance alert, “probable account takeover”. The analyst gets one notice with context instead of five separate ones.

5 Alert quality and false alarms

5.1 Detection errors

Sl. 29

When we check an alert, it is either right or wrong. A missed attack is a miss. There are four results (table 20): TP (true positive: alert and attack), FP (false positive: alert without attack), FN (false negative: attack without alert) and TN (true negative: no attack and no alert). A false positive is a harmless activity that is wrongly classified as harmful [14].

Table 20 — Results of a rule

	There was an attack	**There was no attack**
Alert	TP	FP
No alert	FN	TN

Sl. 30, 31

We describe the quality of a rule with two numbers. **Precision** is the share of correct alerts among all alerts: Precision = TP / (TP + FP). **Recall** is the share of found attacks among all attacks: Recall = TP / (TP + FN). They pull in different directions. A stricter threshold gives fewer false alarms, but more misses.

Example: a rule gave 40 alerts, and 30 of them were correct. In the same period there were 50 attacks. So Precision = 30 / 40 = 0.75 and Recall = 30 / 50 = 0.6. If we raise the threshold, Precision grows and Recall falls.

5.2 Too many alerts for an analyst

Sl. 32

If there are many alerts and most are false, the analyst stops paying attention and starts to miss real ones. Table 21 lists the usual causes.

Table 21 — Causes of many false alarms

Cause	**What happens**
Rules that are too general	They fire on normal behavior
No context	We do not know if the asset is critical
No description of normal work	Any difference looks suspicious
Duplicate rules	One attack gives many alerts of the same kind

5.3 How to reduce false alarms

Sl. 33

Table 22 shows the main ways. Any suppression must be temporary and must have an owner. If not, a real attack can hide in the suppressed alerts.

Table 22 — Ways to reduce false alarms

Way	Idea	Example
Tuning	Raise the threshold, add exceptions	Threshold 5 failures → 10
Enrichment	Use asset context and reputation	Higher importance for production servers
Correlation	Join weak signals	Points for several features
Suppression	Temporarily stay silent about known safe things	A known vulnerability scanner, with a review date
Notification levels	Low importance goes only to a dashboard	Information alerts without notices

Sl. 34

For example, the rule “five failures in five minutes” gives tens of false alarms every day. The reason is a shared office address, where many employees make login mistakes. The fix is to exclude the addresses of corporate gateways, or to count failures for the pair “address and account”.

5.4 Detection as code

Sl. 35

We keep and maintain rules like program code: in version control, with review of changes, automatic format checks, and tests on prepared data. We also measure Precision and Recall of each rule. A template helps to describe each rule, for example the Alerting and Detection Strategy of Palantir. It asks for the goal, the data, the logic, possible false alarms, the way to test and the response steps [15].

6 Response and its automation

6.1 Life cycle of a response

Sl. 37

The current NIST guide SP 800-61 Rev. 3 treats response as a part of cyber risk management. It uses the functions of the NIST CSF 2.0 framework [4], [16]. Three functions matter for a monitoring center: detect (find and analyze events), respond (manage the incident, analyze, contain, remove, report) and recover. The results of each case go back to preparation and to rule improvement (figure 5).

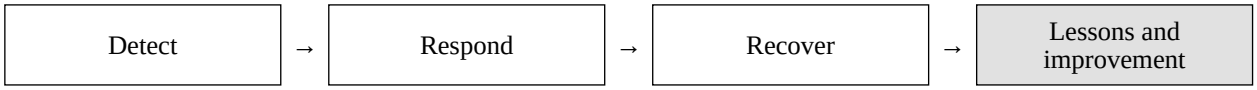


Figure 5 — The response cycle

In our example the response is: block the session, change the password and check what the attacker did. The lesson is a rule tuning.

6.2 Automation of response

Sl. 38

Automation platforms (SOAR) do routine actions. They join the tools of the center and run response scenarios. Table 23 shows common automations.

Table 23 — Common automations

Condition	Automatic action	Risk of the action
Password guessing from an outside address	Block the address on the firewall	Low
Successful login after guessing	Block the account, create an incident case	Medium

We sort automatic actions by risk. Low-risk actions (block an address) run at once. Medium-risk actions (block an account) run with a notice and a chance to undo. High-risk actions (isolate a host, stop a service) run only after a person agrees.

Sl. 39

The scenario for our example: block the outside address. After a successful login, block the account and create an incident case.

7 Summary

Sl. 40

Table 24 shows the main ideas of the lecture.

Table 24 — Main ideas of the lecture

Chapter	Main idea
1. Roles and processes	Three levels of analysts; three decisions for an alert; runbook; metrics of the center
2. Architecture	Monitoring on several levels; collection, delivery, normalization, enrichment, storage, alert management
3. Rules	Sigma: base and correlation rules; sliding windows; adding weak signals
4. Quality	TP, FP, FN, TN; Precision and Recall; too many alerts; detection as code
5. Response	Cycle by NIST SP 800-61 Rev. 3; automation sorted by risk

In practice 2 you write 6–8 detection rules for prepared logs. A script applies them with time windows. You make a report of the alerts and suggest ways to reduce false alarms.

References

[1] National Institute of Standards and Technology, “Risk Management Framework for Information Systems and Organizations,” technical report SP 800-37 Rev. 2, 2018. doi: 10.6028/NIST.SP.800-37r2.

[2] NIST Computer Security Resource Center, “Glossary: alert (по CNSSI 4009).” [Online]. Available: https://csrc.nist.gov/glossary/term/alert

[3] National Institute of Standards and Technology, “Security and Privacy Controls for Information Systems and Organizations,” technical report SP 800-53 Rev. 5, 2020. doi: 10.6028/NIST.SP.800-53r5.

[4] National Institute of Standards and Technology, “Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile,” technical report SP 800-61 Rev. 3, 2025. doi: 10.6028/NIST.SP.800-61r3.

[5] Elastic, “Elastic Security ECS field reference.” [Online]. Available: https://www.elastic.co/docs/reference/security/fields-and-object-schemas/siem-field-reference

[6] Elastic, “Elastic announces open source license for Elasticsearch and Kibana source code.” [Online]. Available: https://www.businesswire.com/news/home/20240829537786/en

[7] OCSF, “Open Cybersecurity Schema Framework.” [Online]. Available: https://schema.ocsf.io/

[8] OASIS, “STIX Version 2.1.” [Online]. Available: https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html

[9] OASIS, “TAXII Version 2.1.” [Online]. Available: https://docs.oasis-open.org/cti/taxii/v2.1/taxii-v2.1.html

[10] SigmaHQ, “Sigma Rules Specification.” [Online]. Available: https://sigmahq.io/sigma-specification/

[11] MITRE, “MITRE ATT&CK.” [Online]. Available: https://attack.mitre.org/

[12] Elastic, “Threshold rules. Elastic Security documentation.” [Online]. Available: https://www.elastic.co/docs/solutions/security/detect-and-alert/threshold

[13] Elastic, “EQL syntax reference.” [Online]. Available: https://www.elastic.co/docs/reference/query-languages/eql/eql-syntax

[14] K. Kent, S. Chevalier, T. Grance, and H. Dang, “Guide to Integrating Forensic Techniques into Incident Response,” technical report SP 800–86, 2006. doi: 10.6028/NIST.SP.800-86.

[15] Palantir, “Alerting and Detection Strategy Framework.” [Online]. Available: https://github.com/palantir/alerting-detection-strategy-framework

[16] National Institute of Standards and Technology, “The NIST Cybersecurity Framework (CSF) 2.0,” technical report CSWP 29, 2024. doi: 10.6028/NIST.CSWP.29.

8 Self-check questions

Each question has a short answer based on the lecture.

1. How does an event differ from an alert and from an incident?

Answer. An event is anything observable in a system or network, for example a record of a failed login. An alert is a notice that a detection rule creates for a suspicious group of events. An incident is a confirmed occurrence that harms confidentiality, integrity or availability. There are many events, few alerts and even fewer incidents.

2. Which three decisions can a first line analyst make for an alert?

Answer. Confirm the threat and pass it to investigation; call it a false alarm and tune the rule; ask for more data and check again after enrichment.

3. Why do we monitor on several levels?

Answer. Each level sees only its part. The network level cannot see inside encrypted traffic. The host level cannot see other hosts. Application logs do not show attacks that did not reach the application. Together the levels give the full picture.

4. Why do we need normalization and enrichment?

Answer. Normalization brings events from different sources to one schema, so one rule works for all of them. Enrichment adds context (importance of the asset, location, reputation), which sets the priority of the alert.

5. Why can fixed windows miss an attack?

Answer. If a series of events falls on the border of two windows, each window has fewer events than the threshold, so there is no alert. A sliding window moves by a small step and catches the whole series.

6. How do we compute Precision and Recall? What happens when we raise the threshold?

Answer. Precision = TP / (TP + FP) and Recall = TP / (TP + FN). With a higher threshold there are fewer alerts and fewer false alarms, so Precision grows. But some attacks do not reach the threshold, so Recall falls.

7. Name three ways to reduce false alarms.

Answer. Tune the threshold and the exceptions; use enrichment with context; add weak signals with points. Suppression is allowed only for a short time and with an owner.

8. Why do we sort automatic actions by risk?

Answer. A wrong block of an address does almost no harm. A wrong isolation of a host or a stopped service breaks the work of the organization. So high-risk actions run only after a person agrees.